

LAB 08 — WEB VULNERABILITY SCANNING: NIKTO

Apache/PHP Reconnaissance & Web Application Security Assessment

CySA+ Home Lab Portfolio | Alejandro W. Orellana | June 29, 2026

1. Scan Overview

Field	Detail
Tool	Nikto v2.5.0
Target	192.168.40.3 — Metasploitable2 (VirtualBox isolated lab)
Port Scanned	80 (HTTP)
Web Server	Apache/2.2.8 (Ubuntu) DAV/2
PHP Version	PHP/5.2.4-2ubuntu5.10 (EOL)
Scan Start	2026-06-29 11:55:44 (GMT-7)
Scan End	2026-06-29 11:56:06 (GMT-7) — 22 seconds
Requests Made	8,910
Total Findings	27 items reported, 0 errors

2. Full Findings — All 27 Items

#	Severity	Path	Finding	Reference
1	CRITICAL	/#wp-config.php#	WordPress config file found — contains database credentials	CWE-538
2	CRITICAL	/phpinfo.php	phpinfo() output exposed — full server configuration disclosed	CWE-552
3	CRITICAL	/phpMyAdmin/	phpMyAdmin exposed — database admin interface accessible	CWE-284
4	HIGH	Server header	Apache/2.2.8 EOL — unsupported, unpatched since 2017	CVE (multiple)
5	HIGH	X-Powered-By	PHP/5.2.4 EOL — critically outdated, RCE vulnerabilities known	CVE-2015-8562
6	HIGH	/	HTTP TRACE enabled — host vulnerable to Cross-Site Tracing (XST)	OWASP XST
7	HIGH	/doc/	Directory indexing — /doc/ browsable, may expose /usr/doc	CVE-1999-0678
8	HIGH	/test/	Directory indexing — /test/ browsable, potential sensitive content	CWE-548
9	HIGH	/icons/	Directory indexing — /icons/ browsable, Apache default exposed	CWE-548
10	HIGH	/phpMyAdmin/ChangeLog	ETag header leaks inode number (92462), file size, mtime	CVE-2003-1418
11	MEDIUM	/	X-Frame-Options header missing — clickjacking attack possible	CWE-1021
12	MEDIUM	/	X-Content-Type-Options missing — MIME sniffing attack possible	CWE-16
13	MEDIUM	/index	mod_negotiation MultiViews enabled — filename brute force possible	OSVDB-8270
14	MEDIUM	/?=PHPB8B5F2A0...	PHP info disclosure via query string	OSVDB-12184

#	Severity	Path	Finding	Reference
15	MEDIUM	/?=PHPE9568F36...	PHP info disclosure via query string	OSVDB-12184
16	MEDIUM	/?=PHPE9568F34...	PHP info disclosure via query string	OSVDB-12184
17	MEDIUM	/?=PHPE9568F35...	PHP info disclosure via query string	OSVDB-12184
18	MEDIUM	/index	Uncommon TCN header found — mod_negotiation artifact	Info
19	MEDIUM	/phpMyAdmin/changel og.php	phpMyAdmin changelog exposed — version fingerprinting	CWE-200
20	MEDIUM	/phpMyAdmin/ChangeL og	phpMyAdmin ChangeLog exposed — version fingerprinting	CWE-200
21	MEDIUM	/phpMyAdmin/Documen tation.html	phpMyAdmin docs exposed — should be restricted	CWE-284
22	MEDIUM	/phpMyAdmin/README	phpMyAdmin README exposed — version/config leakage	CWE-200
23	MEDIUM	/icons/README	Apache default README file accessible	CWE-200
24	LOW	/	Junk HTTP methods return valid response — may cause false positives	Info
25	LOW	/test/	Test directory flagged as potentially interesting	Info
26	LOW	/phpMyAdmin/	phpMyAdmin noted (duplicate reference)	CWE-284
27	LOW	/phpinfo.php	phpinfo() noted (duplicate reference)	CWE-552

CRITICAL	HIGH	MEDIUM	LOW
----------	------	--------	-----

3. Priority Findings — Critical & High Detail

1 — CRITICAL	wp-config.php Exposed	/#wp-config.php#
The WordPress configuration file contains plaintext database credentials including hostname, database name, username, and password. An attacker who retrieves this file has immediate authenticated access to the database without any further exploitation.		
2 — CRITICAL	phpinfo() Exposed	/phpinfo.php
The phpinfo() function outputs the complete PHP and server configuration including: PHP version, loaded modules, server paths, environment variables, and compilation options. This provides an attacker with a detailed reconnaissance map of the server before launching targeted attacks.		
3 — CRITICAL	phpMyAdmin Accessible	/phpMyAdmin/
The phpMyAdmin web interface provides full GUI-based database administration with no network access restriction. Combined with wp-config.php credentials, an attacker has complete database read/write/delete access from any browser. This finding alone constitutes full database compromise.		
4 — HIGH	Apache 2.2.8 End-of-Life	Server header
Apache 2.2.8 was released in 2008 and reached end-of-life in 2017. No security patches are issued for this version. Dozens of known CVEs remain permanently unmitigated — same condition as the Ubuntu EOL OS finding in Lab 03.		
5 — HIGH	PHP 5.2.4 End-of-Life	X-Powered-By header
PHP 5.2.4 is the same version targeted by CVE-2015-8562 — the Joomla RCE vulnerability exploited in the Lab 04 BOTSv1 attack chain. This version has been EOL since 2011 and contains numerous unpatched RCE, SQLi, and XSS vulnerabilities.		
6 — HIGH	HTTP TRACE Enabled	/
The HTTP TRACE method reflects the full request back to the client. Combined with JavaScript, this enables Cross-Site Tracing (XST) attacks that can steal HttpOnly cookies — bypassing a key XSS defense. TRACE should be disabled on all production web servers.		

4. MITRE ATT&CK; Mapping

Technique ID	Name	Tactic	Nikto Finding
T1190	Exploit Public-Facing Application	Initial Access	Apache 2.2.8 EOL + PHP 5.2.4 EOL — unpatched public-facing services
T1592.002	Gather Victim Host Information: Software	Reconnaissance	phpinfo.php discloses PHP version, server paths, loaded modules — full recon map
T1083	File and Directory Discovery	Discovery	Directory indexing on /doc/, /test/, /icons/ exposes server file structure
T1552.001	Credentials in Files	Credential Access	wp-config.php contains plaintext database credentials accessible via HTTP GET
T1505.003	Server Software Component: Web Shell	Persistence	phpMyAdmin provides persistent web-based database access — functionally equivalent to a web shell for data exfiltration
T1040	Network Sniffing / Session Hijacking	Credential Access	HTTP TRACE enabled — enables XST attacks to steal session cookies in transit

5. Cross-Lab Connection — Labs 03, 04 & 08

Lab 08 findings connect directly to prior labs, building a coherent attack narrative across the portfolio:

Lab 08 Finding	Prior Lab Connection	Significance
PHP 5.2.4 EOL	Lab 04 — BOTSv1 CVE-2015-8562	Exact PHP version exploited in the Joomla RCE attack chain I investigated in Splunk
Apache 2.2.8 EOL	Lab 03 — Ubuntu 8.04 EOL (CVSS 10.0)	Same pattern — EOL software = permanent unmitigated exposure
Directory Indexing	Lab 03 — NFS World-Readable (T1083)	Both map to T1083 File and Directory Discovery — same recon technique, different protocol
wp-config.php credentials	Lab 07 — Password Cracking (T1552)	Plaintext credentials in files eliminate the need for cracking entirely

6. Remediation Recommendations

Priority	Action	Implementation
IMMEDIATE	Remove wp-config.php from web root	Move outside document root or restrict via .htaccess. Never store credentials in web-accessible paths.
IMMEDIATE	Remove/restrict phpinfo.php	Delete phpinfo.php from production. If needed for debug, restrict to localhost only.
IMMEDIATE	Restrict phpMyAdmin access	Restrict to specific IPs via Apache config or move behind VPN. Never expose to open network.
CRITICAL	Upgrade Apache (2.2.8 → 2.4.x)	Apache 2.2.x is EOL. Upgrade to current stable release to receive security patches.
CRITICAL	Upgrade PHP (5.2.4 → 8.x)	PHP 5.2.4 is EOL and contains the exact CVE exploited in Lab 04. Upgrade immediately.
HIGH	Disable HTTP TRACE	Add 'TraceEnable off' to Apache config to eliminate XST attack surface.
HIGH	Disable directory indexing	Add 'Options -Indexes' to Apache config for all directories.
MEDIUM	Add security headers	X-Frame-Options: DENY, X-Content-Type-Options: nosniff — add to Apache/PHP config.

Key Takeaway: Nikto completed 8,910 requests in 22 seconds and identified a complete attack chain: reconnaissance via phpinfo.php (T1592) → credential theft via wp-config.php (T1552) → database compromise via phpMyAdmin (T1505) → persistence via EOL software (T1190). Web application scanning should be a standard component of every vulnerability assessment — these findings would not appear in a network-layer Nessus scan alone.